



Ataque Man-in-the-Middle, Certificados e PKI

Prof. Dr. Iaçanã Ianiski Weber

Confiabilidade e Segurança de Software

98G08-4

*Agradecimentos especiais ao Prof. Avelino Zorzo e aos Autores Christof Paar, Jan Pelzl e Tim Güneysu pelo material.
Definições normativas baseadas em publicações do NIST.*

- 1 Estabelecimento de Chave com Técnicas Assimétricas
- 2 Ataque Man-in-the-Middle
- 3 Certificados
- 4 Infraestrutura de Chave Pública (PKI) e CAs
- 5 Revogação de Certificados
- 6 PKI na Prática e Lições Aprendidas

Conteúdo desta Aula

Nesta aula você vai aprender:

- Como a **criptografia de chave pública** estabelece chaves sem o problema n^2 — e qual **novo problema** ela introduz.
- O **ataque Man-in-the-Middle (MITM)**: por que *toda* cifra assimétrica precisa de um **canal autenticado** para distribuir chaves públicas.
- **Certificados**: como uma **assinatura digital** liga (*binds*) uma identidade a uma chave pública, e o papel da **Autoridade Certificadora (CA)**.
- O padrão **X.509** e a **transferência de confiança** (*chain of trust*).
- **Infraestrutura de Chave Pública (PKI)**: componentes, **cadeias de certificados** e hierarquias de CAs.
- **Revogação** de certificados: **CRLs** e **OCSP**.

Onde Paramos: dos Esquemas Simétricos para a Chave Pública

Na aula anterior (Kerberos/KDC) vimos as **limitações dos esquemas simétricos**:

- Em geral, não oferecem **Perfect Forward Secrecy (PFS)**; exigem **canal seguro** na entrada de cada usuário; o KDC é um **ponto único de falha** e precisa ser contatado a cada sessão.

A **criptografia de chave pública** resolve a distribuição de chaves em escala e habilita PFS (ex.: via Diffie–Hellman efêmero) — **ao custo** de exigir a **autenticação das chaves públicas**.

- O registro de uma chave consiste em **ligar (*bind*) material criptográfico a uma entidade**; essa ligação é feita por uma **terceira parte confiável**.
- O NIST cita como exemplos dessa terceira parte “*um servidor de realm Kerberos ou uma **autoridade certificadora (CA)** de uma PKI*”.

Fonte: NIST SP 800-57 Part 1 Rev. 5, §8.1.6 (*Key Registration*); Paar et al., cap. 14.4.

- 1 Estabelecimento de Chave com Técnicas Assimétricas
- 2 Ataque Man-in-the-Middle
- 3 Certificados
- 4 Infraestrutura de Chave Pública (PKI) e CAs
- 5 Revogação de Certificados
- 6 PKI na Prática e Lições Aprendidas

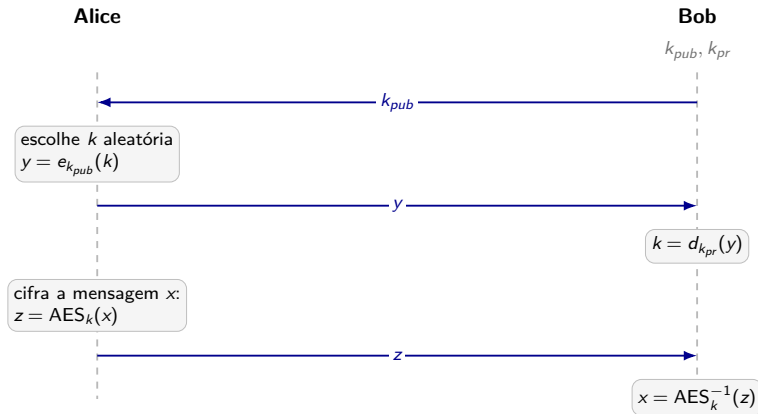
Chave Pública para Estabelecimento de Chave

- Algoritmos de chave pública são especialmente adequados para **estabelecimento de chave** — é, junto da assinatura digital, seu principal domínio de aplicação.
- Servem tanto para **transporte de chave** quanto para **acordo de chave**:
 - **Transporte** (*key transport*): uma parte gera a chave e a envia cifrada (ex.: **RSA**, **Elgamal**).
 - **Acordo** (*key agreement*): ambas contribuem para o valor final (ex.: **Diffie–Hellman** ou sua variante em curvas elípticas, **ECDH**).

Primitivas de chave pública são **lentas**. Por isso, a cifragem dos dados em si quase sempre é feita com uma cifra **simétrica** rápida (ex.: **AES**) *após* o estabelecimento da chave por técnicas assimétricas.

Protocolo Básico de Transporte de Chave

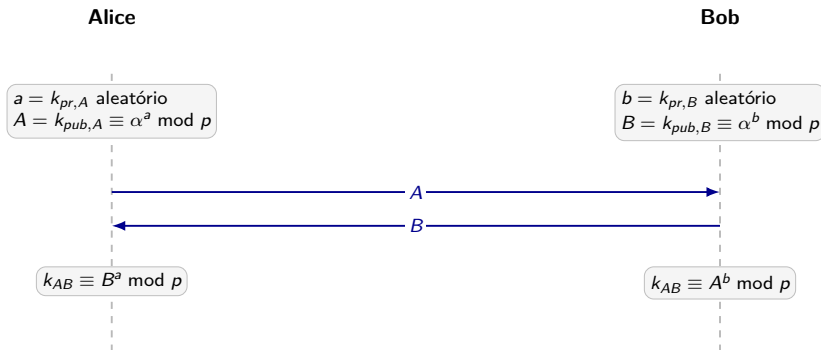
Bob dispõe de um par de chaves (k_{pub}, k_{pr}) . Alice usa k_{pub} para enviar uma chave de sessão k , e os dados seguem cifrados com AES.



Funciona contra um atacante *passivo*. Mas se k_{pub} não for **autenticada**, abre-se a porta para um atacante *ativo*.

Recapitulando: Diffie–Hellman (DHKE)

O DHKE permite que duas partes que *nunca se encontraram* concordem em um segredo compartilhado trocando mensagens por um canal inseguro.



Com parâmetros bem escolhidos (em especial um primo p com **2048 bits ou mais**), o DHKE é seguro contra **escuta** (ataques *passivos*).

O Porém: É Preciso um Canal *Autenticado*

- Parece que a chave pública resolve *todos* os problemas de estabelecimento de chave. Mas há uma condição essencial:

Todo esquema assimétrico exige um **canal autenticado** para distribuir as **chaves públicas**.

- **Canal seguro** (confidencial) $\neq$ **canal autenticado**. A chave pública *não* é secreta — mas sua **origem** precisa ser garantida.
- O NIST é explícito: a distribuição de uma chave pública deve dar ao receptor a garantia de que “*o verdadeiro dono da chave é conhecido (i.e., o suposto dono é o dono real)*”.

Fonte: NIST SP 800-57 Part 1 Rev. 5, §8.1.5.1.1 (*Distribution of Public Keys*); Paar et al., cap. 14.4.

- 1 Estabelecimento de Chave com Técnicas Assimétricas
- 2 **Ataque Man-in-the-Middle**
- 3 Certificados
- 4 Infraestrutura de Chave Pública (PKI) e CAs
- 5 Revogação de Certificados
- 6 PKI na Prática e Lições Aprendidas

Atacante Ativo e a Ideia do MITM

Agora Oscar *não* se limita a escutar: ele pode **interceptar, alterar e gerar** mensagens.

Man-in-the-Middle (MITM) — definição (NIST)

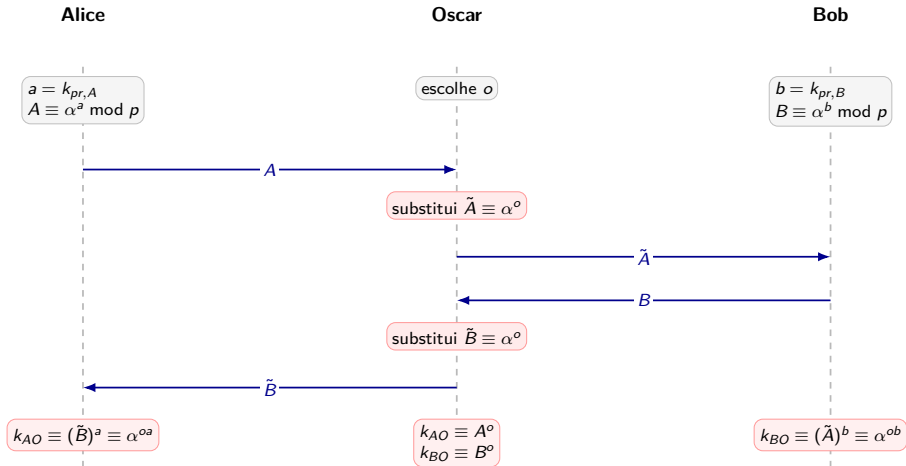
“Uma forma de **escuta ativa** em que o atacante intercepta e modifica seletivamente os dados comunicados para se **passar por** uma ou mais das entidades envolvidas na associação de comunicação.”

(NIST CSRC Glossary; CNSSI 4009-2015 / RFC 4949)

- **Ideia central:** Oscar substitui as chaves públicas de Alice e de Bob *pela sua própria*.
- Isso é possível **sempre que as chaves públicas não são autenticadas**.
- Estudaremos o ataque contra o DHKE, mas ele se aplica a **qualquer** esquema assimétrico sem proteção das chaves públicas.

MITM contra o DHKE

Oscar escolhe um expoente o e injeta $\tilde{A} \equiv \tilde{B} \equiv \alpha^o \bmod p$ no lugar das chaves reais.



As Chaves que Cada Parte Calcula

Ocorrem, na verdade, **dois DHKEs simultâneos**: $Alice \leftrightarrow Oscar$ e $Bob \leftrightarrow Oscar$.

Alice $\leftrightarrow$ Oscar

$$k_{AO} = (\tilde{B})^a \equiv (\alpha^o)^a \equiv \alpha^{oa}$$

$$k_{AO} = A^o \equiv (\alpha^a)^o \equiv \alpha^{ao}$$

(valores idênticos)

Bob $\leftrightarrow$ Oscar

$$k_{BO} = (\tilde{A})^b \equiv (\alpha^o)^b \equiv \alpha^{ob}$$

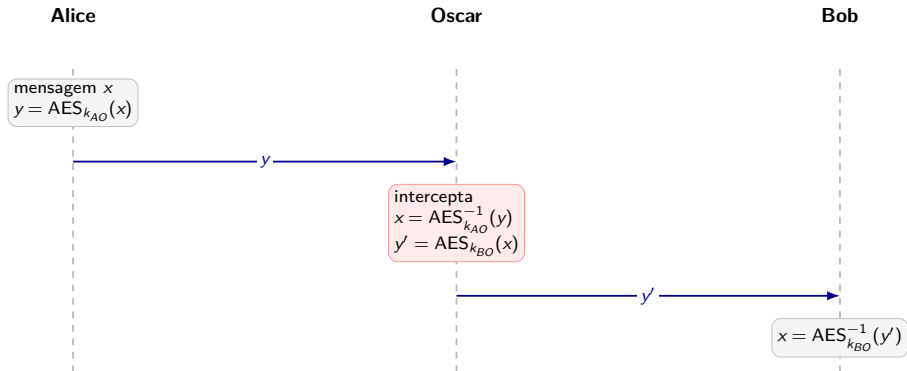
$$k_{BO} = B^o \equiv (\alpha^b)^o \equiv \alpha^{bo}$$

(valores idênticos)

Oscar compartilha k_{AO} com Alice e k_{BO} com Bob. **Nem Alice nem Bob percebem:** ambos acreditam ter calculado uma chave comum k_{AB} *um com o outro*.

Manipulação de Mensagens após o MITM

Estabelecidas k_{AO} e k_{BO} , Oscar lê (e pode **alterar**) todo o tráfego, de forma *imperceptível*:



Oscar pode **ler** x e também **alterá-lo** antes de recifrar com k_{BO} . Consequências graves se x for, por exemplo, uma *transação financeira*.

Consequência: o Canal Autenticado é Imprescindível

- O MITM **não** é restrito ao DHKE: aplica-se a **qualquer** esquema assimétrico. O ataque procede sempre da mesma forma — Oscar intercepta a chave pública enviada e a substitui pela sua.

Ainda que esquemas de chave pública *não* exijam um canal **secreto**, eles exigem um canal **autenticado** para a distribuição das chaves públicas.

- A causa raiz é que a chave $k_A = (k_{pub,A}, ID_A)$ **não está autenticada**.
- **Caminho adiante:** aplicar um mecanismo que garanta **autenticação** da chave pública — os **certificados**.

Fonte: Paar et al., cap. 14.4.1–14.4.2.

- 1 Estabelecimento de Chave com Técnicas Assimétricas
- 2 Ataque Man-in-the-Middle
- 3 Certificados**
- 4 Infraestrutura de Chave Pública (PKI) e CAs
- 5 Revogação de Certificados
- 6 PKI na Prática e Lições Aprendidas

A Raiz do Problema: Chaves Não Autenticadas

Na prática, a chave de Alice tem a forma:

$$k_A = (k_{pub,A}, ID_A)$$

onde ID_A é informação identificadora (nome, e-mail...) e $k_{pub,A}$ é uma mera **cadeia binária** (ex.: 2048 bits).

- Num ataque MITM, Oscar troca a chave por

$$k_A = (k_{pub,O}, ID_A)$$

- Tudo permanece igual, *exceto* a cadeia binária anônima que forma a chave $\Rightarrow$ o receptor **não tem como detectar** que ela é, na verdade, de Oscar.

Precisamos de um mecanismo que **ligue** (*bind*) a identidade ID_A à chave $k_{pub,A}$ de forma verificável. Esse mecanismo é a **assinatura digital**.

A Ideia do Certificado

Como a autenticidade de $(k_{pub,A}, ID_A)$ é violada por um ataque ativo, aplicamos uma **assinatura digital** sobre essa tupla. Um certificado, em sua forma básica, é:

$$\text{Cert}_A = [(k_{pub,A}, ID_A), \text{sig}_{k_{pr,CA}}(k_{pub,A}, ID_A)]$$

Certificado de chave pública — definição (NIST)

“Um conjunto de dados que identifica unicamente uma entidade, contém a chave pública da entidade e possivelmente outras informações, e é **assinado digitalmente por uma parte confiável, ligando** assim a chave pública à entidade.” (NIST SP 800-57 Part 2 Rev.1)

- O receptor **verifica a assinatura** antes de usar a chave. Se Oscar tentar trocar $k_{pub,A}$ por $k_{pub,O}$, isso **será detectado**.
- Diz-se que o certificado **liga a identidade do usuário à sua chave pública**.

A Autoridade Certificadora (CA)

Verificar um certificado exige a chave pública correta de *quem o assinou*. Usar a chave de Alice recairia no mesmo problema — por isso a assinatura vem de uma **terceira parte mutuamente confiável**.

Autoridade Certificadora (CA) — definições (NIST)

“A entidade, em uma PKI, que **emite certificados** para os titulares (*subjects*).” (NIST SP 800-57 Part 1 Rev.5)

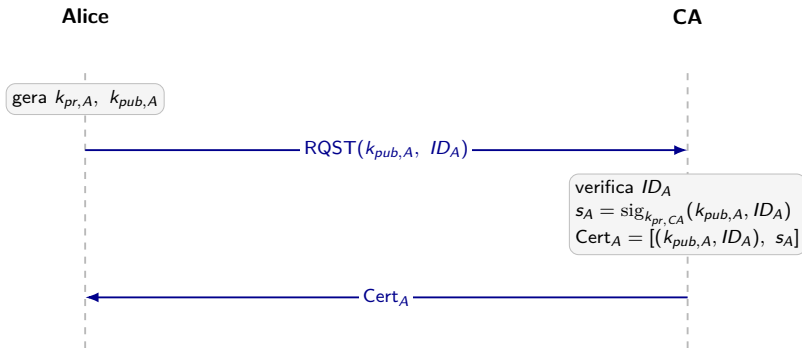
“Uma CA é semelhante a um **cartório/tabelião**: confirma as identidades das partes que se comunicam.” (NIST SP 800-32, §3.1)

Ponte com a aula anterior: o NIST descreve o registro de chaves como uma **ligação feita por uma terceira parte confiável** — citando como exemplos “*um servidor de realm Kerberos*” (caso simétrico) “*ou uma CA de uma PKI*” (caso assimétrico).

Fonte: NIST SP 800-57 Part 1 Rev.5 (§2.1 e §8.1.6); NIST SP 800-32 §3.1; Paar et al., cap. 14.4.2.

Geração de Certificado — chaves geradas pelo usuário

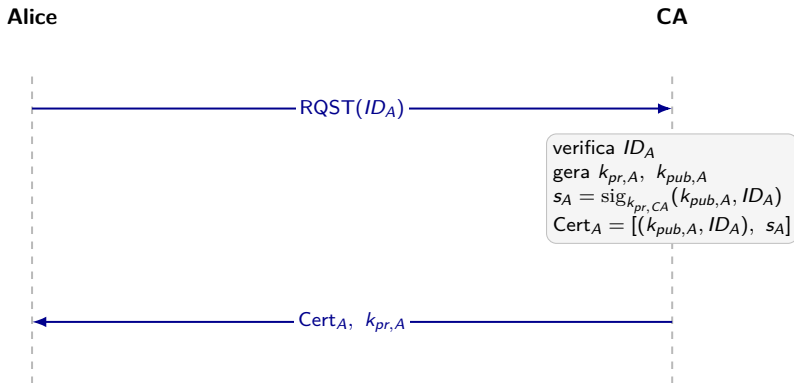
Caso 1: o usuário gera seu próprio par de chaves e pede à CA apenas para **assinar** a chave pública.



A 1ª transmissão é **crítica**: $(k_{pub,A}, ID_A)$ deve ir por um **canal autenticado**; senão Oscar poderia requisitar um certificado *em nome de Alice*.

Geração de Certificado — chaves geradas pela CA

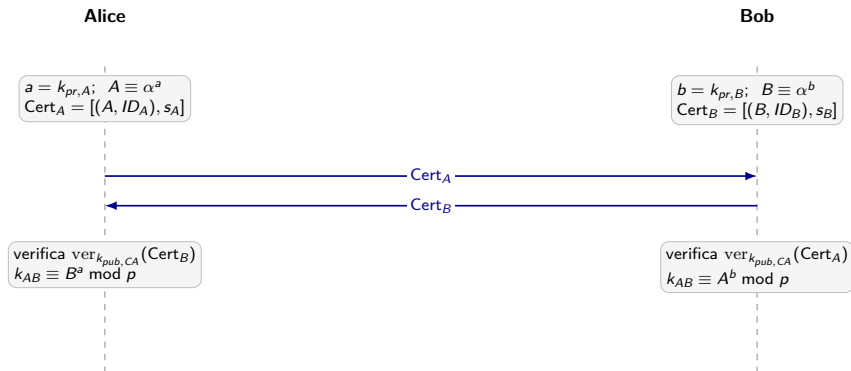
Caso 2: a CA também **gera o par de chaves** de cada usuário.



A 2ª transmissão carrega a **chave privada** $k_{pr,A}$: exige um canal não apenas autenticado, mas **secreto** (ex.: entrega *out-of-band*, por USB/correio).

DHKE com Certificados

Cada parte envia seu certificado; antes de calcular a chave, **verifica** o certificado do outro com a chave pública da CA.



Se Oscar trocar A por $\tilde{A}$, a assinatura s_A **não confere** e o ataque é detectado. A verificação exige a chave pública da CA, $k_{pub,CA}$.

Transferência de Confiança

A verificação ainda exige um **canal autenticado** para obter $k_{pub,CA}$. Parece não termos ganho nada...

...mas a diferença é decisiva: o canal autenticado é necessário **uma única vez**, na *instalação*. As chaves públicas das CAs já vêm **pré-instaladas** em navegadores e sistemas operacionais.

- Sem certificados, Alice e Bob teriam de confiar *diretamente* na chave um do outro.
- Com certificados, basta confiar na chave da CA, $k_{pub,CA}$: tudo que a CA assina passa a ser confiável. Isso é a **cadeia de confiança** (*chain of trust*) — uma **transferência de confiança**.
- O NIST chama a CA confiável de **âncora de confiança** (*trust anchor*): “a chave pública de uma CA confiável é o alicerce de todos os serviços de segurança baseados em PKI”.

Fonte: Paar et al., cap. 14.4.2; NIST SP 800-57 Part 1 Rev.5, §8.1.5.1.1.1 (*trust anchor*).

Certificados X.509

Na prática, certificados são estruturas complexas. O padrão **X.509** é amplamente usado na internet — em **TLS**, **IPsec** e **S/MIME**.

Certificado X.509 (campos)

Nº de série	identificador único
Algoritmo de assin.	ex.: RSA c/ SHA-2
Emissor	quem gerou o certificado
Validade	<i>não antes / não depois</i>
Titular (Subject)	ID_A : nome/organização
Chave pública	valor + algoritmo + parâmetros
Assinatura	sobre <i>todos</i> os campos

- **Validade limitada** (1–2 anos):
reduz a janela de uso se a chave privada vazar ou o titular sair da organização.
- **Dois algoritmos**: o protegido *pelo* certificado e o que *assina* o certificado — podem diferir (ex.: certificado assinado com RSA-2048; chave protegida ECDH-256).

X.509 (NIST)

“O certificado de chave pública X.509... conforme definido pelo padrão ISO/ITU-T X.509.” (NIST SP 800-57 Part 1 Rev.5)

Fonte: Paar et al., cap. 14.4.2 (Fig. 14.5); NIST SP 800-32 §3.3.1; NIST SP 800-57 Part 1 Rev.5.

- 1 Estabelecimento de Chave com Técnicas Assimétricas
- 2 Ataque Man-in-the-Middle
- 3 Certificados
- 4 Infraestrutura de Chave Pública (PKI) e CAs**
- 5 Revogação de Certificados
- 6 PKI na Prática e Lições Aprendidas

O que é uma PKI

Public-Key Infrastructure (PKI) — definição (NIST)

“Um **arcabouço** (*framework*) estabelecido para **emitir, manter e revogar** certificados de chave pública.” (NIST FIPS 186-5)

- Todo o sistema formado pelas **CAs** mais os mecanismos de suporte necessários é chamado de **PKI**.
- Montar e operar uma PKI no mundo real é **complexo**: é preciso estabelecer com segurança a identidade dos usuários na emissão e distribuir as chaves das CAs de forma confiável.
- Entre os aspectos mais complexos: a existência de **muitas CAs diferentes** e a **revogação** de certificados.

Segundo o NIST (SP 800-32), uma PKI apoia quatro serviços básicos de segurança: **integridade, confidencialidade, identificação/autenticação e não-repúdio**.

Componentes de uma PKI

Autoridade Certificadora (CA)

“Entidade, em uma PKI, que **emite certificados** para os titulares.”
Assina-os com sua chave privada e também os **revoga**.

Repositório

Armazena e distribui certificados e **CRLs**.

Autoridade de Registro (RA)

“Uma entidade confiável que **estabelece e atesta a identidade** de um usuário.” Confirma identidades *antes* da emissão.

Parte confiante (*relying party*)

“Parte que **se baseia** na segurança e autenticidade de uma chave” — p.ex. na chave pública contida em um certificado.

Definições (tradução): NIST SP 800-57 Part 1 Rev.5 (§2.1); NIST SP 800-32 (§3.1).

Cadeias de Certificados

Num mundo ideal, uma única CA emitiria certificados para todos. Na prática há **muitas CAs** (governos, empresas comerciais, corporações para seus funcionários).

- Seria inviável um usuário ter à mão a chave pública de *todas* as CAs.
- Solução: as CAs **certificam umas às outras** — a **certificação cruzada** (*cross-certification*).

Caminho de certificação (*certification path*) — NIST

“Uma lista ordenada de certificados... que permite ao receptor verificar que o remetente e todos os certificados intermediários são **confiáveis**.”

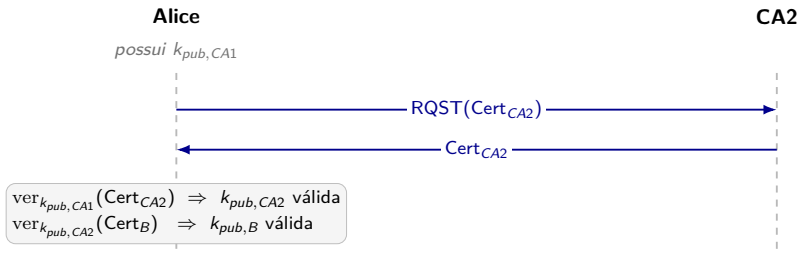
(NIST SP 800-57 Part 2 Rev.1)

Cenário: o certificado de Alice foi emitido por CA1 e o de Bob por CA2. Alice tem só $k_{pub,CA1}$; ao receber $Cert_B$ (assinado pela CA2), ela *não consegue* verificá-lo diretamente.

Verificação via Cadeia (certificação cruzada)

Alice obtém a chave da CA2 dentro de um certificado *assinado pela sua própria CA1*:

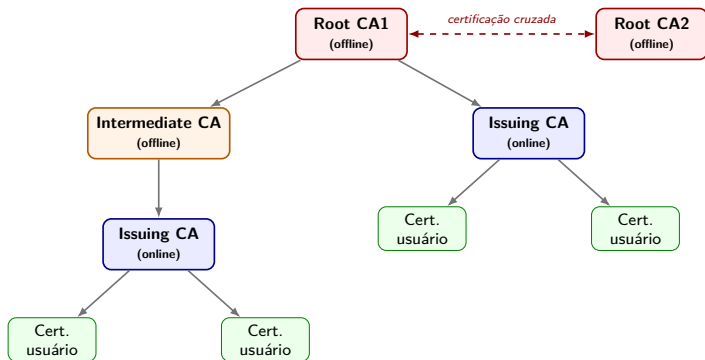
$$\text{Cert}_{CA2} = [(k_{pub, CA2}, ID_{CA2}), \text{sig}_{k_{pr, CA1}}(k_{pub, CA2}, ID_{CA2})]$$



CA1 confia em CA2 (assina sua chave) $\Rightarrow$ Alice passa a confiar na chave de Bob.
A **confiança é delegada** ao longo da **cadeia**.

Hierarquia de CAs

Na prática, CAs se organizam **hierarquicamente**; cada CA assina a chave das CAs do nível abaixo.



Root CA (âncora de confiança): *offline*, certifica raramente as CAs abaixo. **Issuing CAs**: muito expostas (*online*), emitem os certificados de usuário. Se uma Issuing CA é comprometida, a CA acima a **revoga** e substitui. *Sempre verifique a cadeia até a Root CA.* — Fonte: Paar et al., cap. 14.5.1

(Ex. 14.3, Fig. 14.6); NIST SP 800-57 Part 1 Rev.5.

- 1 Estabelecimento de Chave com Técnicas Assimétricas
- 2 Ataque Man-in-the-Middle
- 3 Certificados
- 4 Infraestrutura de Chave Pública (PKI) e CAs
- 5 **Revogação de Certificados**
- 6 PKI na Prática e Lições Aprendidas

Por que Revogar um Certificado

- Certificados têm **data de expiração** — mas os dados podem se tornar **não confiáveis antes** disso. É preciso um mecanismo de *revogação*.

Motivos típicos de revogação (NIST SP 800-32 / livro)

- a **chave privada** do titular foi **perdida ou comprometida** (ex.: *smart card* perdido);
- o titular **deixou** a organização;
- o **nome** do titular mudou.

Discutiremos dois métodos para verificar a validade de um certificado: **CRLs** e **OCSP**.

Fonte: NIST SP 800-32 §3.1 (motivos) e §3.3.2 (expiração/CRL); Paar et al., cap. 14.5.2.

Listas de Revogação de Certificados (CRL)

CRL — definição (NIST)

“Uma **lista de certificados de chave pública revogados**, criada e **assinada digitalmente** por uma autoridade certificadora.”

(NIST CSRC Glossary; FIPS 201-3 / RFC 5280)

- Identifica os revogados pelo **número de série**; *deve* ser assinada pela CA (senão adversários revogariam certificados maliciosamente). É o análogo da “lista negra” de cartões de crédito.
- **Problema — transmissão**: contatar a CA a *cada* certificado recebido recria o gargalo dos esquemas com KDC (a promessa da PKI era *não* precisar de contato *online*).
- **CRLs periódicas** criam uma janela em que o certificado já foi revogado mas o usuário ainda não sabe — *trade-off* entre tráfego de rede e segurança.
- **Delta CRLs**: enviam apenas as *mudanças* desde a última CRL, reduzindo o tamanho.

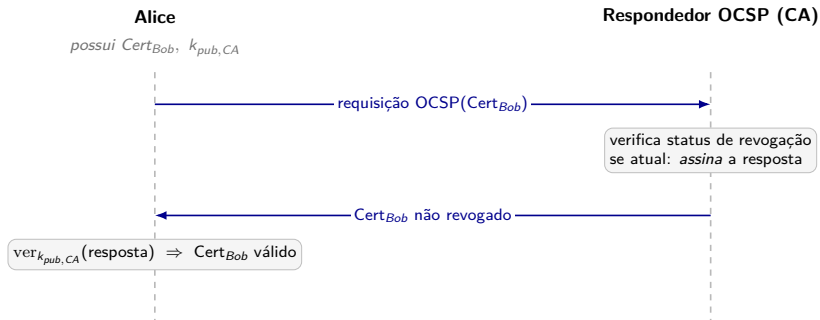
Fonte: NIST SP 800-32 §3.3.2 (analogia da “*hot list*”); Paar et al., cap. 14.5.2.

Online Certificate Status Protocol (OCSP)

OCSP — definição (NIST)

“Um **protocolo online** usado para determinar o **status** de um certificado de chave pública.”

(NIST CSRC Glossary; FIPS 201-3 / RFC 6960)



Determina o status *imediatamente*, sem esperar a próxima CRL. Até a resposta chegar, a aceitação do certificado fica **suspensa**. Suportado por navegadores; publicado na **RFC 6960**.

- 1 Estabelecimento de Chave com Técnicas Assimétricas
- 2 Ataque Man-in-the-Middle
- 3 Certificados
- 4 Infraestrutura de Chave Pública (PKI) e CAs
- 5 Revogação de Certificados
- 6 PKI na Prática e Lições Aprendidas**

Certificados no Mundo Real

- Por razões técnicas e organizacionais, a maioria dos usuários *não* obtém certificados pessoais. Na internet, os certificados servem sobretudo para **autenticar servidores** para os usuários (o servidor é autenticado; o usuário, em geral, não).
- Esse arranjo é aceitável porque é o *usuário* quem fornece a informação sensível (ex.: número do cartão). As chaves de verificação das CAs já vêm **pré-instaladas** em navegadores e SOs.
- **Let's Encrypt** (ISRG) oferece uma CA **gratuita e aberta**, ampliando a adoção de certificados.

CAs são alvos valiosos: conhecida a chave privada da *raiz*, o atacante gera certificados arbitrários. Em **2011**, um certificado falso “*.google.com” foi emitido por uma CA intermediária derivada da **Turktrust**.

Alternativa hierárquica: a **teia de confiança** (*web of trust*) — baseada em relações de confiança entre pares — usada no **PGP/GPG**.

Lições Aprendidas

- **Todo** protocolo assimétrico exige que as chaves públicas sejam **autenticadas** — tipicamente com **certificados**. Caso contrário, são possíveis ataques **Man-in-the-Middle**.
- Um **certificado** liga a identidade de uma entidade à sua chave pública por meio de uma **assinatura digital** de uma **Autoridade Certificadora (CA)** confiável.
- Os certificados realizam uma **transferência de confiança**: basta confiar na chave da CA (**âncora de confiança**); o canal autenticado é necessário *só na instalação*.
- Uma **PKI** é o arcabouço que **emite, mantém e revoga** certificados; lida com **múltiplas CAs** (cadeias/hierarquias) e com a **revogação** (CRLs e OCSP).
- Uma boa **gestão de chaves** é crucial e deve ser considerada por *todo* o ciclo de vida do sistema.

Livro-texto

- C. Paar, J. Pelzl, T. Güneysu. *Understanding Cryptography: From Established Symmetric and Asymmetric Ciphers to Post-Quantum Algorithms*. 2. ed., Springer, 2024 — Cap. 14 (*Key Management*), seções 14.4 e 14.5.

Publicações do NIST

- NIST SP 800-57 Part 1 Rev. 5 — *Recommendation for Key Management: Part 1 – General* (2020).
- NIST SP 800-32 — *Introduction to Public Key Technology and the Federal PKI Infrastructure* (2001).
- NIST FIPS 186-5; NIST SP 800-57 Part 2 Rev. 1; FIPS 201-3.
- NIST CSRC Glossary — <https://csrc.nist.gov/glossary> (termos: *PKI, certification authority, registration authority, public key certificate, X.509 certificate, CRL, OCSP, man-in-the-middle attack*).

Padrões correlatos (citados): ITU-T X.509; IETF RFC 5280 (perfil X.509/CRL); RFC 6960 (OCSP).